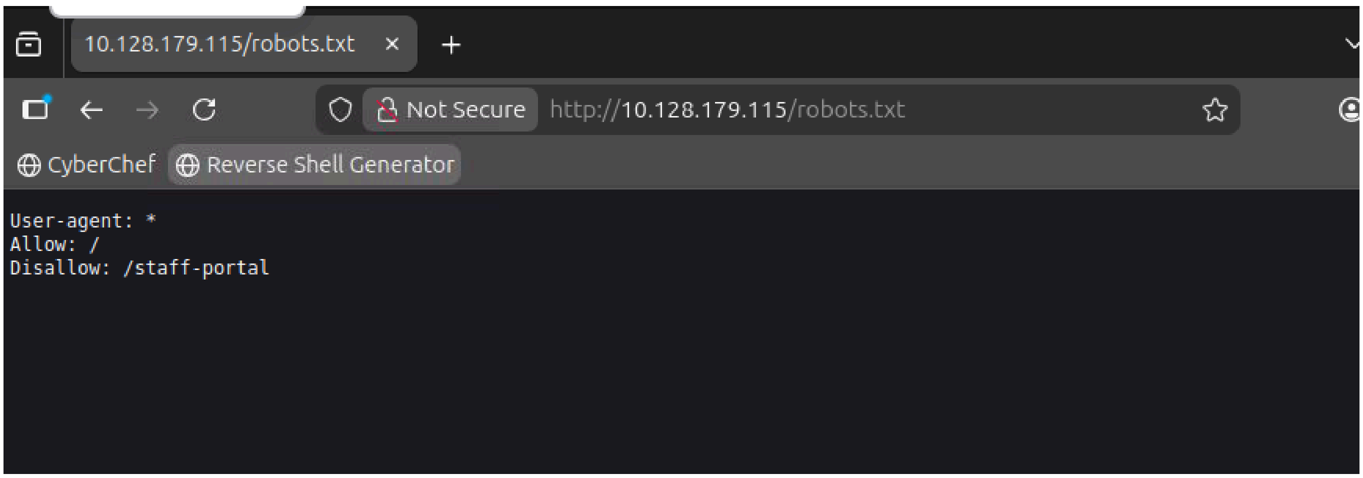
Content Discovery

What Is Content Discovery

There are three main ways of discovering content on a website which we'll cover. Manually, Automated and OSINT (Open-Source Intelligence).

Manual Discovery - Robots.txt

The robots.txt file is a document that tells search engines which pages they are and aren't allowed to show on their search engine results or ban specific search engines from crawling the website altogether. It can be common practice to restrict certain website areas so they aren't displayed in search engine results.



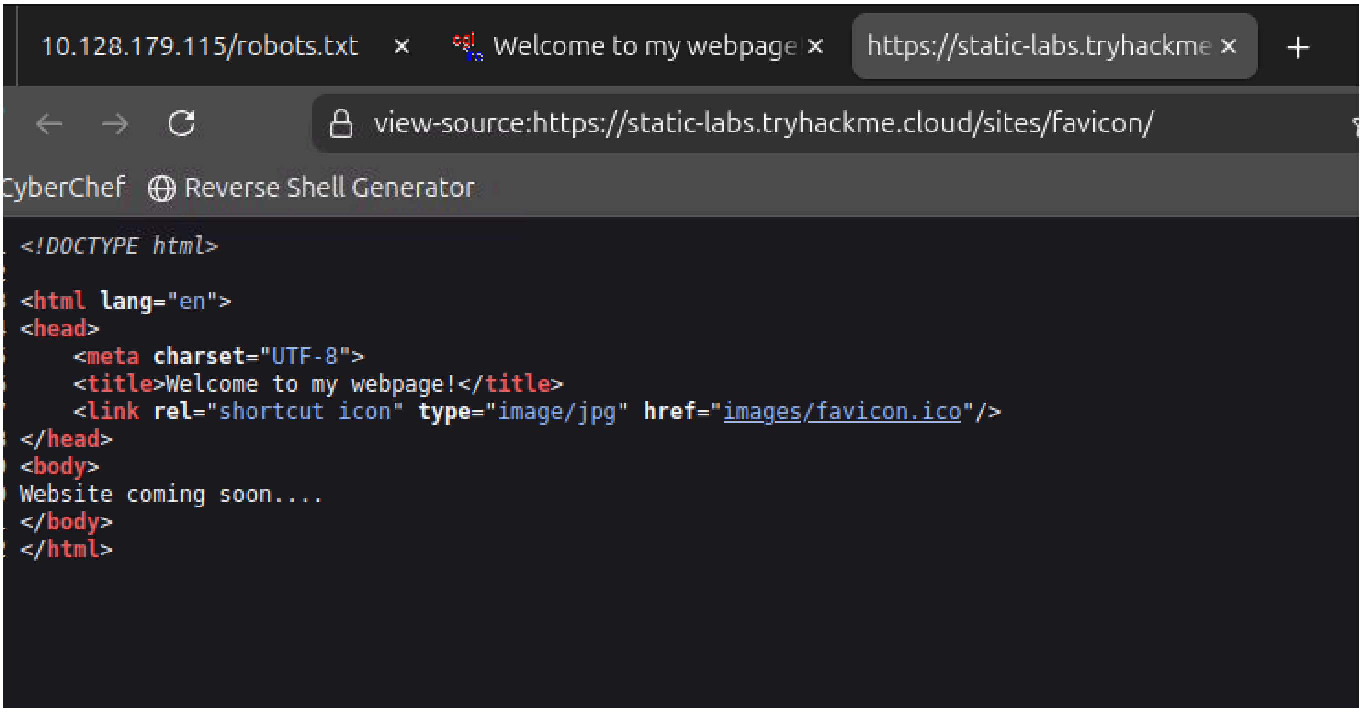
Manual Discovery - Favicon

Favicon

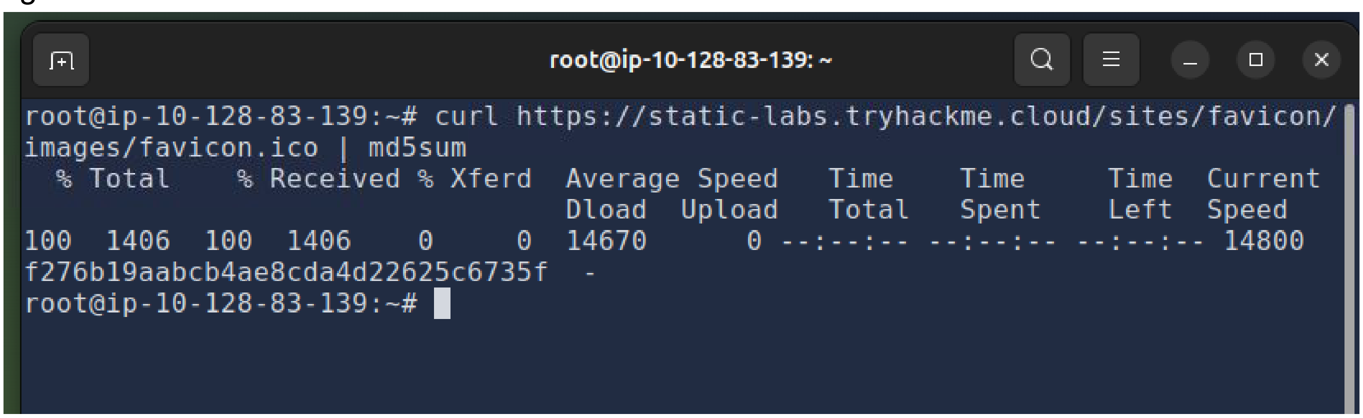
The favicon is a small icon displayed in the browser's address bar or tab used for branding a website.

Sometimes when frameworks are used to build a website, a favicon that is part of the installation gets leftover, and if the website developer doesn't replace this with a custom one, this can give us a clue on what framework is in use.

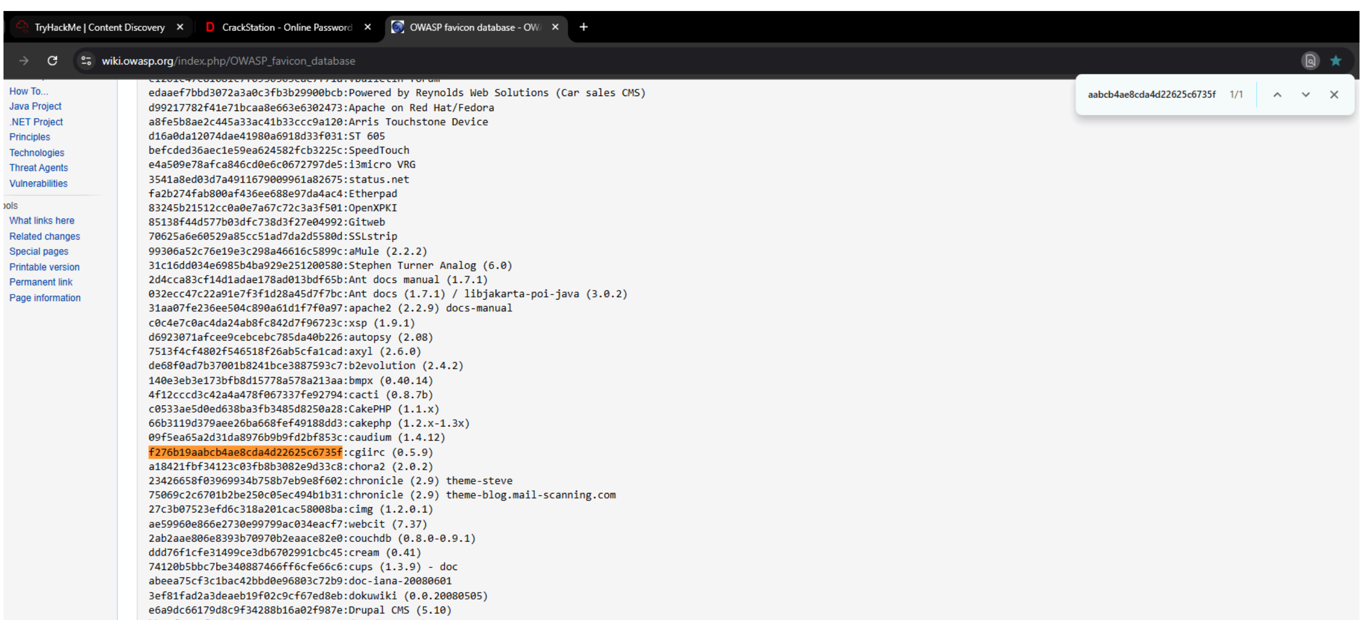
OWASP host a database of common framework icons that you can use to check against the targets favicon [https://wiki.owasp.org/index.php/OWASP_favicon_database(opens in new tab)](https://wiki.owasp.org/index.php/OWASP_favicon_database). Once we know the framework stack, we can use external resources to discover more about it.



i got the md5 sum of the favicon



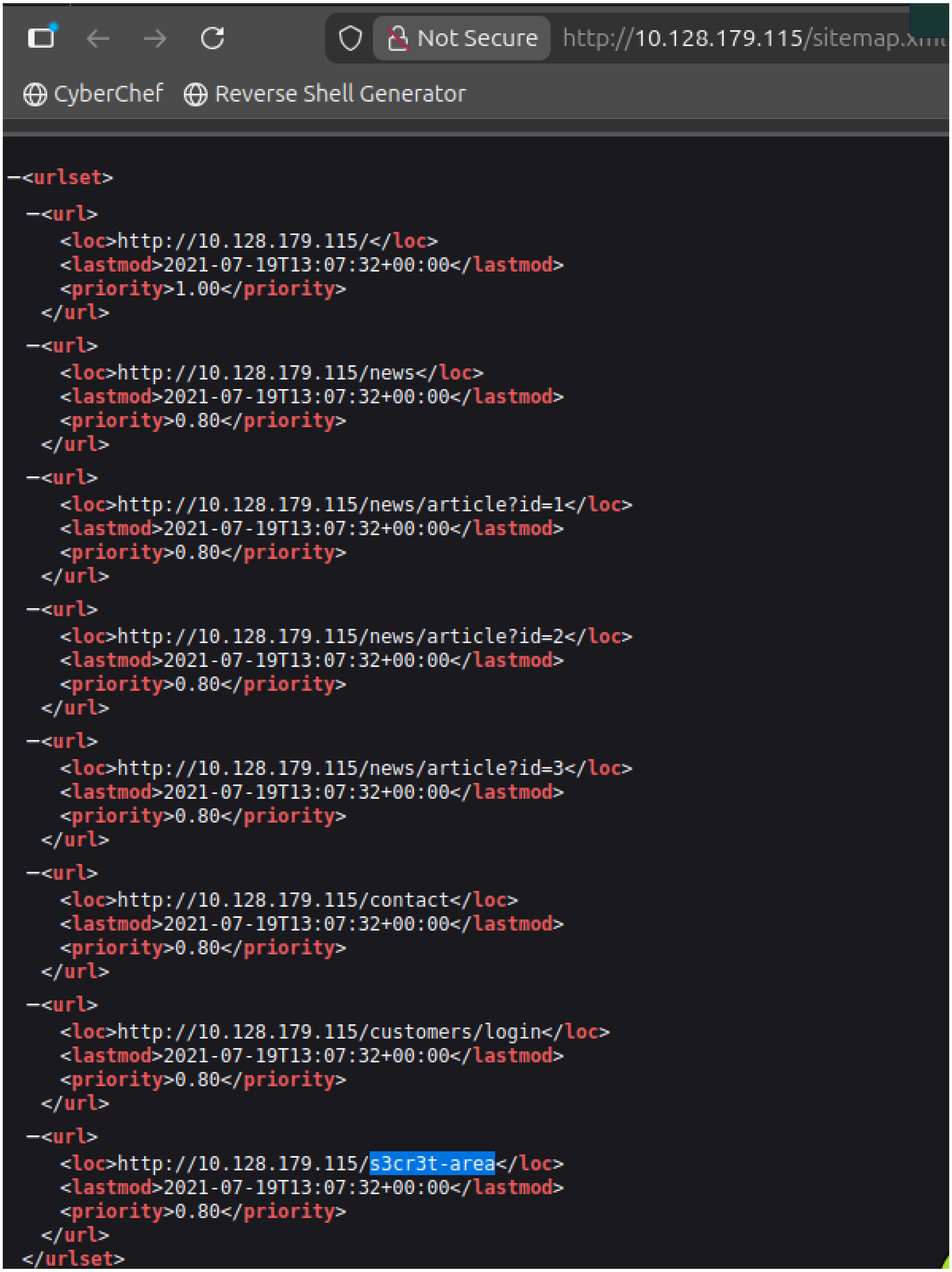
I then went to the OWASP favicon database and searched the hash to find the framework



Manual Discovery - Sitemap.xml

sitemap.xml file gives a list of every file the website owner wishes to be listed on a search engine. These can sometimes contain areas of the website that are a bit more difficult to navigate to or even list some old webpages that the current site no longer uses but are still working behind the scenes.

went on the sitemap.xml and found the secret area




```
-<urlset>
  -<url>
     <loc>http://10.128.179.115/</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>1.00</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/news</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/news/article?id=1</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/news/article?id=2</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/news/article?id=3</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/contact</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/customers/login</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
  -<url>
     <loc>http://10.128.179.115/s3cr3t-area</loc>
     <lastmod>2021-07-19T13:07:32+00:00</lastmod>
     <priority>0.80</priority>
   </url>
 </urlset>
```

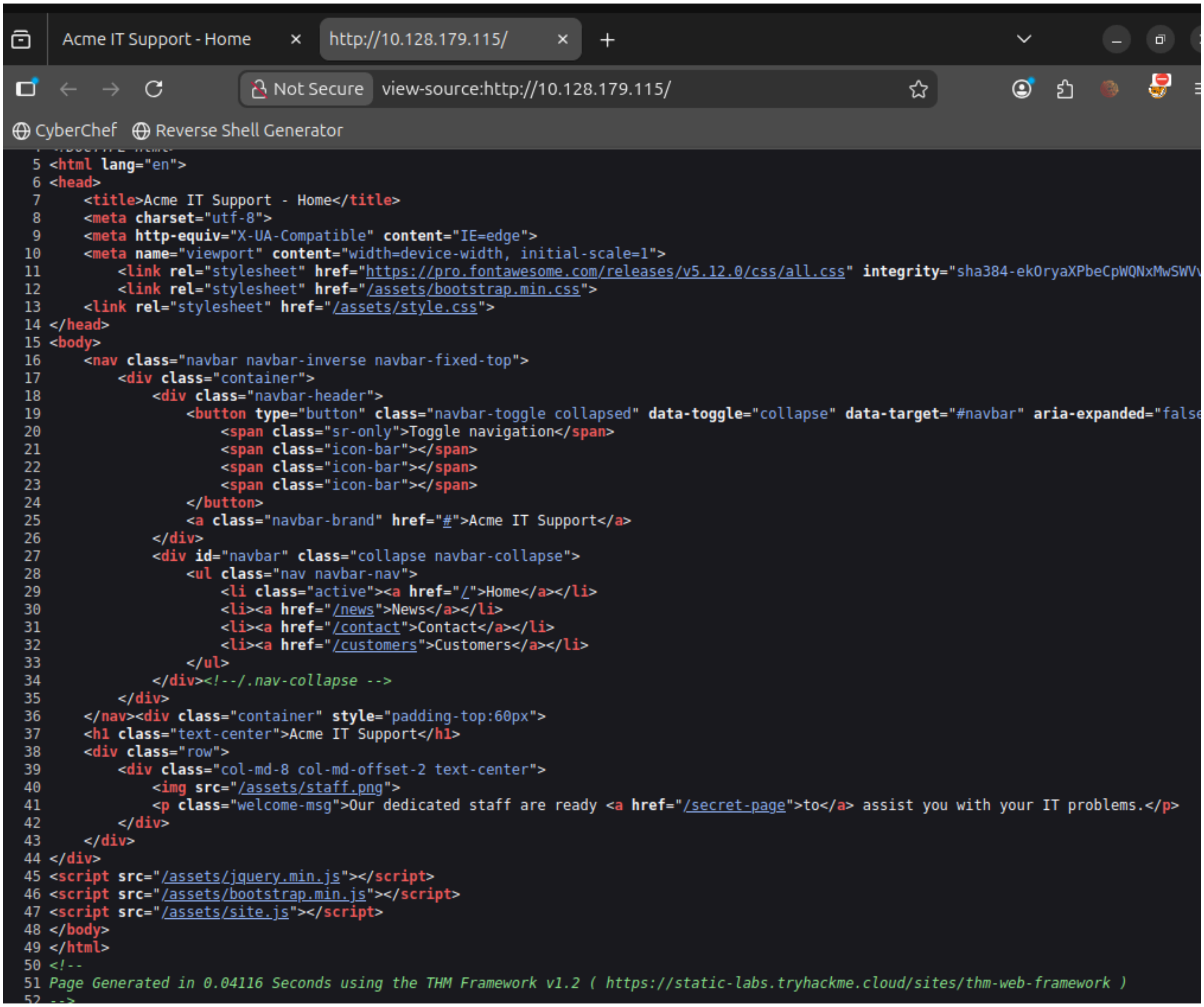
Manual Discovery - HTTP Headers

When we make requests to the web server, the server returns various HTTP headers. These headers can sometimes contain useful information such as the webserver software and possibly the programming/scripting language in use.

```
root@ip-10-128-83-139:~# curl http://10.128.179.115 -v
*   Trying 10.128.179.115:80...
* Connected to 10.128.179.115 (10.128.179.115) port 80
> GET / HTTP/1.1
> Host: 10.128.179.115
> User-Agent: curl/8.5.0
> Accept: */*
>
< HTTP/1.1 200 OK
< Server: nginx/1.18.0 (Ubuntu)
< Date: Mon, 16 Mar 2026 19:21:53 GMT
< Content-Type: text/html; charset=UTF-8
< Transfer-Encoding: chunked
< Connection: keep-alive
< X-FLAG: THM{HEADER_FLAG}
<
<!--
This page is temporary while we work on the new homepage @ /new-home-beta
-->
<!DOCTYPE html>
<html lang="en">
<head>
    <title>Acme IT Support - Home</title>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1">
```

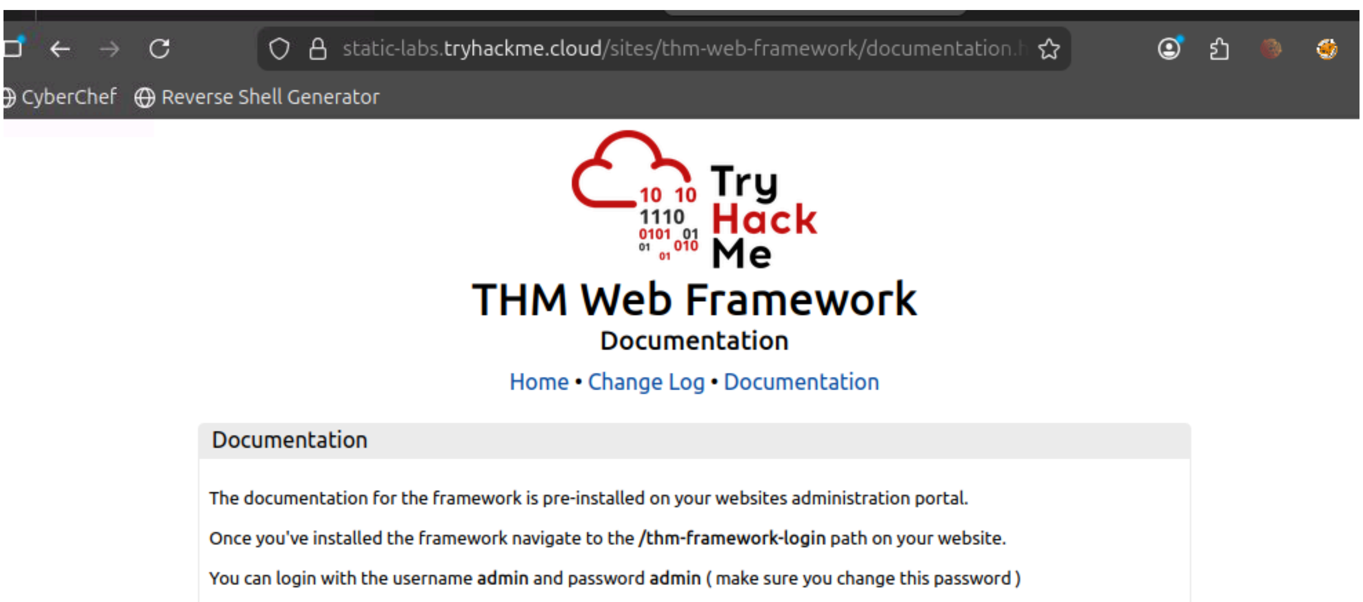
Manual Discovery - Framework Stack

Once you've established the framework of a website, either from the above favicon example or by looking for clues in the page source such as comments, copyright notices or credits, you can then locate the framework's website. From there, we can learn more about the software and other information, possibly leading to more content we can discover.

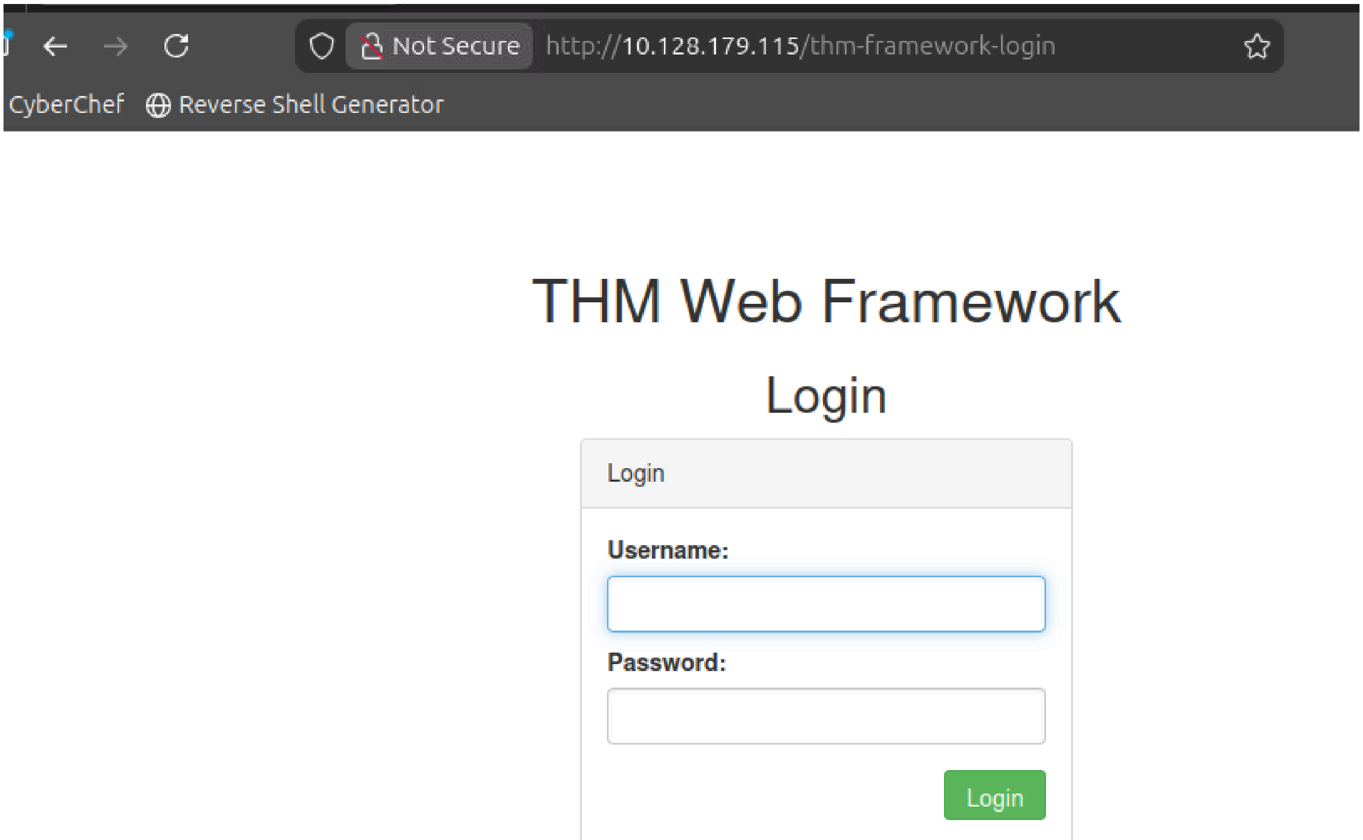



```html
<html lang="en">
<head>
    <title>Acme IT Support - Home</title>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1">
        <link rel="stylesheet" href="https://pro.fontawesome.com/releases/v5.12.0/css/all.css" integrity="sha384-ekOryaXPbeCpWQNxMwSWV
        <link rel="stylesheet" href="/assets/bootstrap.min.css">
    <link rel="stylesheet" href="/assets/style.css">
</head>
<body>
    <nav class="navbar navbar-inverse navbar-fixed-top">
        <div class="container">
            <div class="navbar-header">
                <button type="button" class="navbar-toggle collapsed" data-toggle="collapse" data-target="#navbar" aria-expanded="false
                    <span class="sr-only">Toggle navigation</span>
                    <span class="icon-bar"></span>
                    <span class="icon-bar"></span>
                    <span class="icon-bar"></span>
                </button>
                <a class="navbar-brand" href="#">Acme IT Support</a>
            </div>
            <div id="navbar" class="collapse navbar-collapse">
                <ul class="nav navbar-nav">
                    <li class="active"><a href="/">Home</a></li>
                    <li><a href="/news">News</a></li>
                    <li><a href="/contact">Contact</a></li>
                    <li><a href="/customers">Customers</a></li>
                </ul>
            </div><!--/.nav-collapse -->
        </div>
    </nav><div class="container" style="padding-top:60px">
    <h1 class="text-center">Acme IT Support</h1>
    <div class="row">
        <div class="col-md-8 col-md-offset-2 text-center">
            <img src="/assets/staff.png">
            <p class="welcome-msg">Our dedicated staff are ready <a href="/secret-page">to</a> assist you with your IT problems.</p>
        </div>
    </div>
</div>
<script src="/assets/jquery.min.js"></script>
<script src="/assets/bootstrap.min.js"></script>
<script src="/assets/site.js"></script>
</body>
</html>
<!--
Page Generated in 0.04116 Seconds using the THM Framework v1.2 ( https://static-labs.tryhackme.cloud/sites/thm-web-framework )
```

at the bottom it tells the framework and a link that takes us to it



then going to that path on the ACME website gives us the login page in which i was able to login with admin admin as it said on the framework page what to use to login then i got a flag



OSINT - Google Hacking / Dorking

freely available tools that collect information

Google Hacking / Dorking

Google hacking / Dorking utilizes Google's advanced search engine features, which allow you to pick out custom content. You can, for instance, pick out results from a certain domain name using the **site:** filter

Filter	Example	Description
site	site:tryhackme.com	returns results only from the specified website address
inurl	inurl:admin	returns results that have the specified word in the URL
filetype	filetype:pdf	returns results which are a particular file extension
intitle	intitle:admin	returns results that contain the specified word in the title

OSINT - Wappalyzer

Wappalyzer

Wappalyzer (https://www.wappalyzer.com/(opens in new tab)) is an online tool and browser extension that helps identify what technologies a website uses, such as frameworks, Content Management Systems (CMS), payment processors and much more, and it can even find version numbers as well.

OSINT - Wayback Machine

The Wayback Machine (https://archive.org/web/(opens in new tab)) is a historical archive of websites that dates back to the late 90s. You can search a domain name, and it will show you all the times the service scraped the web page and saved the contents. This service can help uncover old pages that may still be active on the current website.

OSINT - GitHub

Repositories can either be set to public or private and have various access controls. You can use GitHub's search feature to look for company names or website names to try and locate repositories belonging to your target. Once discovered, you may have access to source code, passwords or other content that you hadn't yet found.

OSINT - S3 Buckets

S3 Buckets are a storage service provided by Amazon AWS, allowing people to save files and even static website content in the cloud accessible over HTTP and HTTPS. The owner of the files can set access permissions to either make files public, private and even writable. Sometimes these access permissions are incorrectly set and inadvertently allow access to files that shouldn't be available to the public. The format of the S3 buckets is http(s)://**{name}.s3.amazonaws.com**(opens in new tab) where {name} is decided by the owner, such as tryhackme-assets.s3.amazonaws.com(opens in new tab). S3 buckets can be discovered in many ways, such as finding the URLs in the website's page source, GitHub repositories, or even automating the process. One common automation method is by using the company name followed by common terms such as **{name}**-assets, **{name}**-www, **{name}**-public, **{name}**-private, etc.

Automated Discovery

Automated discovery is the process of using tools to discover content rather than doing it manually. This process is automated as it usually contains hundreds, thousands or even millions of requests to a web server. These requests check whether a file or directory exists on a website, giving us access to resources we didn't previously know existed. This process is made possible by using a resource called wordlists.

What are wordlists?
Wordlists are just text files that contain a long list of commonly used words; they can cover many different use cases.

Automation Tools
Although there are many different content discovery tools available, all with their features and flaws, we're going to cover three which are preinstalled on our attack box, ffuf, dirb and gobuster.

Tools:

ffuf

ffuf -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt -u http://10.128.179.115/FUZZ

dirb

dirb http://10.128.179.115/ /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt

gobuster

gobuster dir --url http://10.128.179.115/ -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt